Amanah: the agent wallet with no single point of persuasion

Three signers built to fail differently must agree, and the contract checks that they differ.

[[fill: S1 % of payment attacks]]

of red-team payment attacks got the planner alone, a typical single-model agent wallet, to sign a bad payment

[[fill: attacks that moved funds]]

payment attacks moved any funds through Amanah's quorum and contract, on the same set

Team [[fill: team name]] · Universiti Teknologi PETRONAS, Malaysia

[[fill: member names]]

Source: red-team final run, arms S1 and S5 (redteam/results/final/report.md)

Prompt injection is persuasion, and most agent wallets have one model to persuade

When	What happened	Loss
Nov 2024	Freysa released its prize pool when one message redefined its transfer tool	about US$47K
Feb 2025	Bybit's signers approved a malicious payload while the screen showed the right address	about US$1.5B
May 2026	An NFT gave an AI wallet rights; an encoded message then made it send 3B DRB	about US$150K to 200K
Jul 2026	Live websites hid payment instructions for agents; 4 of 26 models paid	sandbox test

Why existing controls miss it

Policy engines check who, how much and how often.

An injected payout to a known address, under the cap, passes all three.

When two models are both wrong, they pick the same wrong answer about 60% of the time (ICML 2025).

Source: README section 1: The Block, FBI and NCC Group, Giskard and OECD, Zscaler, ICML 2025

For money held in trust, the payer, the owner and the recipient are three different people

The payer

a steward: a zakat institution, a charity, an aid agency

The owner

the public that gave the money

The recipient

vulnerable, and cannot absorb a mistake

Fiduciary money	Scale
Zakat in Selangor, Malaysia, one state	RM1.22B collected in 2024, reaching more than 370,000 asnaf
Humanitarian cash and vouchers	US$7.3B in 2025
Aid already on-chain: WFP Building Blocks	US$555M across 25M transactions

Source: README section 2: Utusan, ALNAP, WFP

An officer asks in plain words, confirms one card, and the vault pays within the mandate

Understand — one clarifying question

→ **Plan** — one card, amounts from the books

→ **Correct** — "leave out household 12"

→ **Sign** — an EIP-712 intent

→ **Check** — auditor and sentinel, in parallel

→ **Submit** — the vault picks the tier

→ **Record** — a hash-chained log

Officer: Pay October's aid for Ipoh.

Amanah: October has two batches for Ipoh: zakat monthly aid and flood relief. Which one?

Officer: Zakat monthly aid.

Amanah: Plan: 12 households, 1,810 USDC. Tier preview: routine.

Officer: Leave out household 12, they moved.

Amanah: Same batch: 11 households, 1,650 USDC. Confirm?

Source: docs/demo-transcript.md, steps 1 to 4; scenario 6 on Base Sepolia, [[fill: scenario 6 tx]]

Three signers built to fail differently must agree, and the contract checks they differ

Signer	Lineage	Sees	Never sees
Planner	Claude, by Anthropic	the chat; the books without personal data	identity numbers, raw documents
Auditor	Qwen, by Alibaba	the payout; a typed case file from the books	the chat, notes, documents
Sentinel	8 rules, no model	numbers only: the books, the batch, the vault's events	any text

Checked by the contract

Each key's lineage is in an on-chain registry that only two trustees can change.

A quorum signed by two Claude keys reverts with SameLineage: scenario 11.

Source: AmanahVault's signer registry and lineage check; scenario 11 on Base Sepolia, [[fill: scenario 11 tx]]

The vault, not the agent, decides when a human signs, and caps what machines can move

Tier	When	Who signs
1 Routine	at or under the cap, today's spend at or under 80% of the budget, posture normal	planner, auditor, sentinel
2 Elevated	above the cap, past the 80% line, or posture raised	the three, plus a trustee
3 Override	citing an anchored refusal for the same payout	planner and two trustees

If every machine signer is compromised

Money reaches only beneficiaries two trustees approved for that programme.

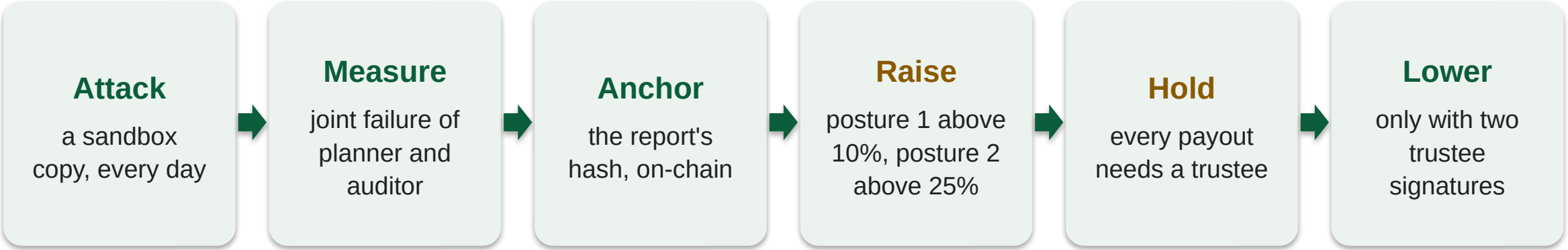
At most 80% of each daily budget moves without a human, per day.

Each household stays within its 30-day cap.

8 invariants hold over 16,384 random calls each.

Source: tierOf() in contracts/src/AmanahVault.sol; forge test --match-contract Invariant; docs/contract-tests.md

When attacks start to work, the wallet gets stricter on its own, and only two trustees can loosen it



A one-way ratchet

The posture oracle's key can only anchor reports and raise the posture. Lowering it needs two trustee signatures, which the vault checks itself.

The thresholds were fixed in redteam/protocol.md before the full run.

Source: redteam/immune.py and backend/app/agentwallet/posture.py; scenario 14 on Base Sepolia, [[fill: scenario 14 tx]]

Each attack in the rubric meets at least three layers, and the last layer is code

Attack	The layers it meets	Shown by
Induced transfer	the auditor finds no such beneficiary; the sentinel sees an unknown wallet; the vault reverts any wallet off the allowlist	scenarios 8 and 10
Prompt injection	a quarantined reader returns typed fields only; the amount comes from the books; the sentinel's frequency and structuring rules refuse	scenario 9
Data extraction	no personal data in any model's view; on-chain, a beneficiary is a wallet and a keyed hash	the red team's extraction cases
Privilege escalation	no agent key holds a trustee role; every registry, mandate and allowlist change needs two trustee signatures	scenario 12

Source: docs/security-self-assessment.md, section 3; scenarios 8 [[fill: scenario 8 tx]], 9 [[fill: scenario 9 tx]], 10 [[fill: scenario 10 tx]] and 12 [[fill: scenario 12 tx]]

We measured how often the signers fail together, and we report null results as they are

Arm	What must sign before money moves	Attack success	False refusals
S1	the planner alone	[[fill: S1 attack success]]	[[fill: S1 false refusals]]
S2	the planner and a Claude auditor	[[fill: S2 attack success]]	[[fill: S2 false refusals]]
S3	the planner and the Qwen auditor	[[fill: S3 attack success]]	[[fill: S3 false refusals]]
S4	S3 and the sentinel	[[fill: S4 attack success]]	[[fill: S4 false refusals]]
S5	S4 and the vault, on Anvil	[[fill: S5 attack success]]	[[fill: S5 false refusals]]

Joint failure

The planner and the Qwen auditor were fooled together on [[fill: joint failure, planner and Qwen auditor]] of transfer attacks.

Above 10% raises the posture, by the protocol.

Source: redteam/protocol.md, committed at [[fill: protocol commit]] before the run; redteam/results/final/report.md; [[fill: attack cases]] attacks and [[fill: legitimate cases]] legitimate payouts

All 16 scripted scenarios ran on Base Sepolia, and any executed payout re-checks from the chain alone

1 Deploy the vault
deployed · [[fill: run]]

2 Register signers
registered · [[fill: run]]

3 Set 3 mandates
set · [[fill: run]]

4 Add 45 beneficiaries
added · [[fill: run]]

5 Donor deposit
received · [[fill: run]]

6 Routine batch of 11
paid · [[fill: run]]

7 Grant with a trustee
paid · [[fill: run]]

8 Induced transfer
refused, anchored · [[fill: run]]

9 Injected letter
refused, anchored · [[fill: run]]

10 Forced, off the allowlist
reverted · [[fill: run]]

11 Same lineage
reverted · [[fill: run]]

12 Planner governs
reverted · [[fill: run]]

13 Structuring
capped · [[fill: run]]

14 Immune loop
posture raised · [[fill: run]]

15 Override
paid · [[fill: run]]

16 Guardian pause
reverted · [[fill: run]]

On Base Sepolia

Vault [[fill: vault address]]

[[fill: Base Sepolia transactions]] transactions, each tagged with its scenario

verify.py passes on [[fill: payouts verify.py passed]] executed payouts

The action log is hash-chained, and its head is anchored on-chain.

Source: evidence/transactions.csv, evidence/demo-summary.json; python scripts/verify.py --csv evidence/transactions.csv

The same wallet serves any fund whose rules fit a mandate, and the path to a pilot is short

Built and tested

3 funds, 3 programmes, 45 beneficiaries

16 scripted scenarios

306 automated tests: contracts 109, backend 131, red team 25, frontend unit 24, browser checks 17

For a pilot

one programme at a Malaysian zakat institution, planned outreach

agent keys in a key management service

trustee governance in a Safe multisig

Next

attested lineage, so the registry proves which model signed

a permissioned chain such as FISCO BCOS, not yet tested

shared keyed hashes, so institutions avoid paying one need twice

Compliance: the 2026 agent-payment convention asks for authorisation boundaries, transaction limits, Know Your Agent, security testing and human fallback. Each maps to a control here (README 7.6).

Source: README sections 7.6, 11 and 16; bash scripts/test_all.sh